

## 2.1.4 Practice - Regulations

When planning and scoping a penetration test, there are often many regulatory compliance considerations. Although some of these regulations do not apply to Pixel Paradise, it's important that you are aware of them for as we broaden your client engagements. Match the compliance description or requirement with the relevant regulatory framework.

Categories:

Payment Card Industry Data Security Standard (PCI DSS)

A

NIST SP 800-57

B

General Data Protection Regulation (GDPR)

C

Health Insurance Portability and Accountability Act (HIPAA)

D

Gramm-Leach-Bliley Act (GLBA)

E

Options:

✓

safeguards electronic health information

✓

applies to all financial services organizations, regardless of size

✓

strengthens and unifies data privacy protections for individuals within the European Union

✓

secures the processing of credit card and other types of digital payments

✓

guidelines for encryption key management

A

D

B

C

E

A

B

C

D

E

## 2.1.8 Practice - Legal Concepts

During our penetration testing contract negotiations with Pixel Paradise, we need to agree to a number of legal considerations. Match the requirement with the legal concept that we negotiated.

Categories:

Service-level agreement (SLA)

A

Disclaimer

B

Confidentiality

C

Non-disclosure agreement (NDA)

D

Options:

✓

specifies and defines confidential material, knowledge, and information that should be kept confidential and not be disclosed to outside parties

✓

documented minimum and maximum performance expectations of the penetration test service

✓

statements such as "The penetration test report cannot and does not protect against personal or business loss resulting from the test agreement."

✓

agreement regarding how to communicate and handle sensitive data, such as account credentials that were uncovered by the testing

A

B

C

D

D

A

B

C

## 2.2.3 Practice - Rules of Engagement

Protego has just signed a new client and you need to review the rules of engagement before getting started on the project. What three components of the agreement are relevant to the rules of engagement? (Choose three.)

access to source code

☒ the times of day the testing will occur

cost of the service and payment schedule

☒ the types of tests that will be allowed or disallowed

☒ the timeline of the testing

the names and credentials of personnel performing the testing

## 2.2.5 Practice - Target List and In-Scope Assets

You are studying the penetration testing agreement for a new engagement with one of Protego's customers. You are especially interested in the information that the client will provide to Protego to support the test. What technical assets may be identified as provided in the scope of the test? (Choose three.)

☒ system architecture and network topology documents

☒ API documentation

non-disclosure agreements

the service-level agreement

credentials and skills of the penetration testing team

☒ wireless SSIDs

## 2.2.8 Practice - Strategy: Unknown vs. Known Environment Testing

You have been asked to participate in an unknown-environment penetration test. What information do you expect will be provided to your team?

- application source code and database schemas
- network infrastructure and security device configurations
- ☒ minimal information that may include IP addresses and domain names
- physical and logical network diagrams

### Skills Check

In the lab, what is the client's biggest concern regarding scope of the test and the rules of engagement?

- that client end-user systems may be vulnerable to denial of service attacks
- ☒ that inventory and shipping systems may be vulnerable to ransomware
- that wireless networks are vulnerable to on-path attacks
- that there are software vulnerabilities in their hosted web services
- I don't know

### Skills Check

What three sections are typically found in a penetration testing agreement? (Choose three.)

- the names of all personnel involved in the test
- ☒ the scope of the work
- ☒ costs and payment details
- a list of vulnerabilities that were discovered
- ☒ the project timeline

## 2.3.2 Practice – Demonstrate an Ethical Hacking Mindset

As an employee of Protego, we expect you to demonstrate professionalism and integrity at all times. Match each of the following ethical hacking practices with the associated activities.

Categories:

limiting the use of tools used in a penetration test

identification and immediate reporting of criminal activity

background checks of penetration testing teams

adherence to the specific scope of engagement

limiting invasiveness based on scope

A

B

C

D

E

Options:

✓

Check the credentials and skills of the individuals performing the penetration test.

✓

Specify the allowed, or disallowed, testing tools.

✓

Report evidence of any system or network that was previously compromised.

✓

Specify tools and attacks that could be detrimental and disruptive for your client's systems.

✓

Create a list of applications, systems, or networks to be tested.

C

A

B

E

D

### Skills Check

What two ethical principles (among others) were violated in the Equifax data breach? (Choose two.)

✓

the obligation to protect personal data

the obligation to destroy evidence of the breach

the obligation to pay a mutli-million dollar penalty

the obligation to destroy customer data on request

✓

the obligation to inform customers that their data had been disclosed

### Question 1

A contractor is hired to review and perform cybersecurity vulnerability assessments for a local health clinic facility. Which U.S. government regulation must the contractor understand before the contractor can start?

GDPR

GLBA

✓

HIPAA

FedRAMP

## Question 2

An Internal Revenue Service office in New York is considering moving some services to a cloud computing platform. Which U.S. government regulation must the office follow in the process?

- GDPR
- FFIEC
- HIPAA
- ☒ FedRAMP

## Question 3

An US university in California plans to offer online courses to students in partner universities in France and Germany. Which regulation should the university follow when those courses are offered?

- ☒ GDPR
- HIPAA
- FERPA
- FedRAMP

## Question 4

Which U.S. government agency is responsible for enforcing the Privacy of Consumer Financial Information Rule of the Gramm-Leach-Bliley Act (GLB Act)?

- ☒ Federal Trade Commission (FTC)
- Securities and Exchange Commission (SEC)
- Commodity Futures Trading Commission (CFTC)
- Federal Deposit Insurance Corporation (FDIC)

## Question 5

In the healthcare sector, which term defines an entity that processes nonstandard health information it receives from another entity into a standard format?

- health plan
- healthcare provider
- business associates
- ☒ healthcare clearinghouse

## Question 6

In the healthcare sector, which term is used to define an entity that provides payment for medical services?

- ☒ health plan
- healthcare provider
- business associates
- healthcare clearinghouse

## Question 7

In e-commerce, what determines the application of the Payment Card Industry Data Security Standard (PCI DSS) requirements?

- merchant
- payment brand
- ☒ primary account number
- approved scanning vendor

## Question 8

What are two examples of sensitive authentication data associated with a payment card that requires compliance with the Payment Card Industry Data Security Standard (PCI DSS)? (Choose two.)

☐ expiration date

☐ cardholder name

☒ CAV2/CVC2/CVV2/CID

☐ primary account number

☒ full magnetic strip data or equivalent data on a chip

## Question 9

Match the parts of Recommendation for Key Management in the NIST SP 800-57 to the description.

**Categories:**

Part 2: Best Practices for Key Management Organization

Part 3: Application Specific Key Management Guidance

Part 1: General

**Options:**

☒ provides general guidance and best practices for the management of cryptographic keying material

☒ provides guidance on policy and security planning requirements for U.S. government agencies

☒ provides guidance when using the cryptographic features of current systems

A

B

C

C

A

B

## Question 10

An employee of a cybersecurity consulting firm in the U.S. is assigned to help assess the system and operation vulnerabilities of several financial institutions in Europe. The task includes penetration tests for compliance. What is a key element the employee must have before starting the assignment?

☐ state-of-the-art penetration testing tools

☐ valid user credentials to perform tests at each client institution

☐ detailed network diagrams and asset inventories from each client institution

☒ documentation of permission for performing the tests from the client institutions

## Question 11

A company hires a cybersecurity professional to perform penetration tests to assess government regulation compliance. Which legal document should be provided to the cybersecurity professional that specifies the expectations and constraints, including quality of work, timelines, and cost?

- statement of work (SOW)
- ☒ service-level agreement (SLA)
- non-disclosure agreement (NDA)
- master service agreement (MSA)

## Question 12

A company hires a cybersecurity professional to perform penetration testing to assess government regulation compliance. Which document will be provided to the cybersecurity professional that specifies a detailed and descriptive list of all the deliverables, including the scope of the project, the timeline and report delivery schedule, the location of the work, and the payment schedule?

- ☒ statement of work (SOW)
- service-level agreement (SLA)
- master service agreement (MSA)
- non-disclosure agreement (NDA)

## Question 13

A company hires a cybersecurity consultant to perform penetration testing to assess government regulation compliance. The company wants the consultant to disclose information to them and no one else. Which type of NDA agreement should be presented to the consultant?

- mutual NDA
- bilateral NDA
- ☒ unilateral NDA
- multilateral DNA



## Question 14

A company hires a cybersecurity consultant to perform penetration testing to assess government regulation compliance. Which document must the consultant receive that specifies the agreement between the consultant and the company for the penetration testing engagement?

- ☒ contract
- ☐ disclaimers
- ☐ statement of work
- ☐ non-disclosure agreement

## Question 15

A company hires a cybersecurity consultant to perform penetration testing to assess government regulation compliance. The consultant is preparing the final report after the penetration testing is completed. In which section of the report should the consultant cover the limitation of the work performed, such as the only dates when the testing is performed and that the findings mentioned in the report do not guarantee that all vulnerabilities are covered?

- ☒ disclaimers
- ☐ scope of work
- ☐ findings and analysis
- ☐ non-disclosure statement

## Question 16

A company hires a cybersecurity consultant to perform penetration tests and review the rules of engagement documents. What are three examples of typical elements in the rules of engagement document? (Choose three.)

- ☒ testing timeline
- ☐ payment schedule
- ☒ location of testing
- ☐ non-disclosure agreement
- ☒ preferred method of communication
- ☐ unknown-environment testing condition

## Question 17

A company hires a cybersecurity consultant to perform penetration tests and review the rules of engagement documents. The consultant notices that one element specifies that the tests should be performed toward only web applications on websites `www1.company.com` and `www2.company.com`, with no social engineering attacks and no cross-site scripting attacks. Which element in the document is used for the specification?

- location of testing
- ☒ types of allowed or disallowed tests
- IP addresses or networks from which testing will originate
- the security controls that could potentially detect or prevent testing

## Question 18

A company hires a cybersecurity consultant to assess applications using different APIs. Which document should the company provide to the consultant about an XML-based language used to document a web service's functionality?

- GraphQL documentation
- Swagger (OpenAPI) documentation
- ☒ Web Services Description Language (WSDL) document
- Web Application Description Language (WADL) document

## Question 19

A company hires a cybersecurity consultant to assess applications using different APIs. Which document should the company provide to the consultant about a query language for APIs and a language for executing queries at runtime?

- ☒ GraphQL documentation
- Swagger (OpenAPI) documentation
- Web Services Description Language (WSDL) document
- Web Application Description Language (WADL) document

## Question 20

A company hires a cybersecurity consultant to assess vulnerability on crucial web application devices such as web and database servers. Which document should the company provide to help the consultant document and define what systems are in the testing?

- examples of application requests
- source codes of the applications
- ☒ system and network architectural diagram
- software development kit (SDK) for specific applications

## Question 21

A company hires a cybersecurity consultant to perform penetration tests. What can cause scope creep of the engagement?

- lack of up-to-date testing tools
- lack of system and network architectural diagrams
- poor formatted request for proposal (RFP) by the company
- ☒ ineffective identification of what technical and nontechnical elements will be required for the penetration test

## Question 22

A company hires a cybersecurity consultant to perform penetration tests. What should be the consultant's first step in validating the engagement scope?

- Confirm the contents of the request for proposal (RFP).
- Request user credentials in accessing targeted systems.
- ☒ Question the company contact person and review contracts.
- Ensure that systems and network architectural diagrams are accurate.

## Question 23

A company hires a cybersecurity consultant to perform penetration tests. The consultant is working with the company to set up communication procedures. Which two protocols should be considered for exchanging emails securely? (Choose two.)

- SCP
- ☒ PGP
- SFTP
- HTTPS
- ☒ S/MIME

## Question 24

A company hires a cybersecurity consultant to perform penetration tests. The consultant is discussing with the company about the penetration testing strategy. Which statement describes the term unknown-environment testing?

- This is a type of testing where the scope of the work could be extended later.
- This is a type of testing where the time frame of the work can be flexible and extension is possible.
- This type is a type of testing where the budget can be further negotiated throughout the testing.
- ☒ This type of testing is where the consultant will be provided with very limited information about the targeted systems and network.

## Question 25

A company hires a cybersecurity consultant to perform penetration tests. What is the key difference between unknown-environment testing and known-environment testing?

- the types of systems and network to be tested
- ☒ the amount of information provided to the consultant
- the tools and types of tests allowed during testing
- credentials and certificates required of the consultant